

TOPS TECH Task 9 (CS)

Task-10 Describing VAPT and VAPT Reports Writing

- 1. Write a brief explanation (in your own words) of what VAPT (Vulnerability Assessment and Penetration Testing) is, and list two differences between Vulnerability Assessment and Penetration Testing.**

Ans:

Introduction to VAPT and Difference Between Vulnerability Assessment and Penetration Testing

What is VAPT?

- VAPT (Vulnerability Assessment and Penetration Testing) is a security testing process used to identify, analyzes, and evaluate security weaknesses in an application, network, system, or website.
- The primary objective of VAPT is to discover vulnerabilities before malicious attackers can exploit them and to provide recommendations for improving overall security.
- Vulnerability Assessment focuses on identifying and listing security weaknesses, while Penetration Testing goes a step further by attempting to exploit those vulnerabilities in a controlled environment to determine their actual impact.
- Together, they help organizations strengthen their security posture and protect sensitive data from cyber threats.

Differences Between Vulnerability Assessment (VA) and Penetration Testing (PT)

- Purpose
- Vulnerability Assessment is used to identify and report security vulnerabilities present in a system.
 - Penetration Testing is used to actively exploit identified vulnerabilities to determine the extent of potential damage.

TOPS TECH Task 9 (CS)

Testing Approach ○ Vulnerability Assessment is generally automated and focuses on scanning and detecting weaknesses.

- Penetration Testing involves both automated and manual techniques to simulate real-world cyberattacks and evaluate security defences.

- ⇒ VAPT is an essential cybersecurity practice that helps organizations identify and mitigate security risks.
- ⇒ While Vulnerability Assessment helps in discovering weaknesses, Penetration Testing validates those weaknesses by simulating actual attacks.
- ⇒ Together, they provide a comprehensive understanding of an organization's security posture.

2. Imagine you are performing a VAPT for a food delivery app like Zomato. Identify and describe three common vulnerabilities you would check for in such an app.

Ans:

Common Vulnerabilities in a Food Delivery Application (Like Zomato)

- When performing a Vulnerability Assessment and Penetration Testing (VAPT) on a food delivery application such as Zomato, it is important to identify security weaknesses that could affect user data, business operations, and overall application security. ○ The following are three common vulnerabilities that should be checked during the assessment.

TOPS TECH Task 9 (CS)

SQL Injection (SQLi):

Description:

- SQL Injection occurs when an application does not properly validate user input before sending it to the database.
- An attacker may inject malicious SQL queries through input fields such as login forms, search bars, or feedback forms.

Impact:

- Unauthorized access to sensitive customer data.
- Modification or deletion of database records.
- Exposure of payment and order information.

Recommendation

- Use parameterized queries, prepared statements, and proper input validation to prevent malicious SQL commands from being executed.

Broken Authentication and Session Management

Description:

- Broken Authentication vulnerabilities occur when the application's login and session management mechanisms are not properly implemented.
- Attackers may exploit weak passwords, predictable session IDs, or insecure authentication processes.

Impact:

- Unauthorized access to user accounts.
- Account takeover attacks.
- Exposure of personal and financial information.

Recommendation:

TOPS TECH Task 9 (CS)

- Implement strong password policies, Multi-Factor Authentication (MFA), secure session handling, and account lockout mechanisms after multiple failed login attempts.

Insecure API Endpoints:

Description:

- Food delivery applications heavily rely on APIs to communicate between mobile applications, web servers, and databases.
- Improperly secured APIs may allow attackers to access or manipulate sensitive data without authorization.

Impact: ○ Exposure of customer information. ○ Unauthorized access to order details.
○ Data manipulation and business logic abuse.

Recommendation:

- Implement proper authentication and authorization controls, use secure API tokens, validate all API requests, and regularly monitor API activity for suspicious behavior.
- ⇒ Food delivery applications process large amounts of customer, order, and payment data, making security a critical requirement.
- ⇒ SQL Injection, Broken Authentication, and Insecure APIs are among the most common vulnerabilities that should be assessed during a VAPT engagement.
- ⇒ Identifying and mitigating these vulnerabilities helps ensure the confidentiality, integrity, and availability of application data.

TOPS TECH Task 9 (CS)

3. Create a sample VAPT report template in a Word or Google Docs file for a fictional e-wallet app (like Paytm). Your template should include sections for Executive Summary, Methodology, Vulnerabilities Found, Risk Ratings, and Recommendations.

Ans:

Sample VAPT Report Template for a Fictional E-Wallet Application Vulnerability Assessment and Penetration Testing (VAPT) Report

Project Information ○ **Application Name:** Secure Pay E-Wallet Application (Fictional) ○ **Client Name:** Tops Technologies ○ **Testing Type:** Vulnerability Assessment and Penetration Testing (VAPT) ○ **Testing Date:** 19/06/2026 ○ **Report Version:** 1.0 ○ **Prepared By:** Security Assessment Team

1. Executive Summary:

Objective:

- The objective of this VAPT engagement was to assess the security posture of the Secure Pay E-Wallet Application and identify vulnerabilities that could potentially affect the confidentiality, integrity, and availability of user data and financial transactions.

Scope:

- The assessment covered:
 - Mobile Application
 - Web Application
 - Backend APIs
 - User Authentication System
 - Payment Processing Functions
- Overall Risk Rating**

TOPS TECH Task 9 (CS)

Risk Level: Medium

⇒ A total of 5 vulnerabilities were identified during the assessment, including High, Medium, and Low-risk findings.

2. Methodology:

- The assessment was performed using industry-standard VAPT methodologies and security testing techniques.

Phase 1: Information Gathering ○

- Application Reconnaissance ○
- Asset Identification ○ Technology
- Stack Enumeration

Phase 2: Vulnerability Assessment ○

- Automated Vulnerability Scanning ○
- Configuration Review ○ Security
- Misconfiguration Checks

Phase 3: Penetration Testing ○

- Authentication Testing ○
- Authorization Testing ○ Input
- Validation Testing ○ Session
- Management Testing ○ API
- Security Testing

Phase 4: Reporting ○

- Documentation of Findings ○
- Risk Analysis
- Recommendations for Remediation

3. Vulnerabilities Found:

Finding 1

TOPS TECH Task 9 (CS)

Vulnerability Name

- Broken Authentication

Description

- Weak password requirements may allow attackers to compromise user accounts through brute-force attacks.

Risk Level:

- High

Impact:

- Unauthorized access to user accounts and sensitive information.

Recommendation:

- Implement strong password policies and Multi-Factor Authentication (MFA).

Finding 2:

Vulnerability Name:

- Insecure API Endpoint

Description:

- Certain API endpoints lacked proper authorization controls.

Risk Level:

- High

Impact:

- Unauthorized access to transaction data.

Recommendation:

- Implement proper authentication and role-based access control.

TOPS TECH Task 9 (CS)

Finding 3:

Vulnerability Name:

- Information Disclosure

Description:

- Application error messages reveal internal system details.

Risk Level:

- Medium

Impact:

- Attackers may gain useful information for further attacks.

Recommendation:

- Use generic error messages and disable detailed system information.

4. Risk Ratings:

<u>Severity</u>	<u>Description</u>
Critical	Immediate action required. Severe impact on business and users.
High	Significant security risk requiring urgent remediation.
Medium	Moderate security risk requiring planned remediation.
Low	Minor security issue with limited impact.
Informational	No direct risk but security improvement is recommended.

5. Recommendations:

TOPS TECH Task 9 (CS)

- The following recommendations are suggested to improve the security of the application:
 - Implement Multi-Factor Authentication (MFA).
 - Enforce strong password policies.
 - Secure all API endpoints using authentication and authorization controls.
 - Perform regular vulnerability assessments.
 - Encrypt sensitive user and transaction data.
 - Implement proper session management controls.
 - Maintain regular security patch updates.

**4. Given the following scenario: During a VAPT of a movie ticket booking app, you discover that user passwords are stored in plain text in the database. Write a short VAPT report entry describing this vulnerability, its risk level, and a recommendation to fix it.

Hint: Use clear, professional language and cover what the risk is and how to mitigate it.**

Ans:

VAPT Report Entry – Plain Text Password Storage

Vulnerability Title:

- Plain Text Password Storage

Vulnerability Description ○ During the Vulnerability Assessment and Penetration Testing (VAPT) of the movie ticket booking application, it was observed that user passwords are stored in plain text format within the database.

- This means that passwords are stored exactly as entered by users without any encryption or hashing mechanism.
- If an attacker gains unauthorized access to the database through a security breach, misconfiguration, or insider threat, all user passwords can be viewed directly.
- This significantly increases the risk of account compromise and unauthorized access to user information.

TOPS TECH Task 9 (CS)

Risk Level: ○
Critical

Impact: ○ The storage of passwords in plain text can have severe consequences, including:

- ▢ Complete exposure of user credentials if the database is compromised.
- ▢ Unauthorized access to user accounts.
- ▢ Credential stuffing attacks against other platforms where users may reuse the same password.
- ▢ Loss of user trust and reputation damage to the organization.
- ▢ Potential legal and regulatory compliance violations.

Recommendation:

- Passwords should never be stored in plain text format. ○ It is strongly recommended to implement secure password hashing mechanisms such as bcrypt, Argon2, or PBKDF2 before storing passwords in the database. ○ Additionally, the following security measures should be implemented:
 - ▢ Use strong password hashing algorithms with unique salts.
 - ▢ Enforce strong password policies.
 - ▢ Implement Multi-Factor Authentication (MFA).
 - ▢ Regularly review and audit authentication mechanisms.
 - ▢ Encrypt sensitive data wherever applicable.

Remediation Priority:

- Immediate
- ⇒ The identified vulnerability poses a critical risk to user account security and data protection.
- ⇒ Immediate remediation is required to ensure passwords are securely stored using industry-standard hashing algorithms and to prevent unauthorized access in the event of a database compromise.